



المدرسة الوطنية للعلوم التطبيقية - بني ملال

ⵜⴰⵎⴰⵔⵜ ⵜⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵔⴰⵎⴰⵏⵜ | ⵜⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵔⴰⵎⴰⵏⵜ - ⵎⴰⵏ ⵜⴰⵎⴰⵏⴰⵢⵜ

Ecole Nationale des Sciences Appliquées - Béni Mellal

ÉCOLE NATIONALE DES SCIENCES APPLIQUÉES DE BENI MELLAL

Université Sultan Moulay Slimane | Filière : IA & Cybersécurité

DOCUMENT D'ANALYSE JURIDIQUE

Conception d'un Système IA Responsable et Conforme au RGPD

Rédigé par

AGOURRAM Hajar

BOUARAFA Sara

Encadrant

Pr. TOUIL

Module : Éthique et Droit du Numérique

Année universitaire : 2025–2026

1. Introduction et Contexte

Ce document constitue l'analyse juridique et réglementaire du projet de déploiement d'un système d'intelligence artificielle (IA) à l'ENSA Béni Mellal. Ce système vise à générer des contenus automatisés, assister la prise de décision académique et traiter des données non sensibles, dans le cadre du module Éthique et Droit du Numérique.

L'analyse couvre : l'application des principes RGPD, l'identification des bases légales, la garantie des droits des personnes, la réalisation d'une AIPD, et la définition d'un cadre de gouvernance éthique et responsable.

2. Analyse Juridique : Cadre RGPD

2.1 Responsable de Traitement

Conformément à l'article 4 et 7 du RGPD, le responsable de traitement est l'entité qui détermine les finalités et les moyens du traitement. Dans ce projet :

Élément	Détail
Responsable de traitement	ENSA Béni Mellal
Représentant légal	Le Directeur de l'ENSA Béni Mellal
Finalité du traitement	Assistance pédagogique, génération de contenus, aide à la décision académique
Données traitées	Identifiants internes, historiques de requêtes, journaux d'activité anonymisés

2.2 Base Légale du Traitement (Art. 6 RGPD)

La base légale principale retenue est l'article 6.1.e du RGPD (mission d'intérêt public), l'ENSA étant un établissement public d'enseignement supérieur. Le consentement (Art. 6.1.a) est recueilli à titre complémentaire à la première utilisation.

Base légale	Applicabilité	Justification
Art. 6.1.e -Mission d'intérêt public	Principale	Mission pédagogique publique de l'ENSA
Art. 6.1.a- Consentement	Complémentaire	Recueilli lors de la première connexion
Art. 6.1.f - Intérêt légitime	Secondaire	Amélioration des services pédagogiques à documenter

2.3 Principes Fondamentaux (Art. 5 RGPD)

Principe	Application au système	Mesure concrète
Licéité	Base légale documentée Art. 6.1.e	Registre des activités de traitement tenu à jour
Minimisation	Collecte limitée au strict nécessaire	Interdiction technique de saisir données personnelles
Limitation des finalités	Usage exclusivement pédagogique	Politique d'utilisation contraignante, contrôle d'accès
Limitation conservation	Durée maximale définie	Purge auto logs 12 mois; historique 2 ans
Intégrité & Sécurité	Mesures techniques et organisationnelles	Authentification, chiffrement, journalisation
Accountability	Responsabilisation documentée	AIPD, DPO désigné, audit annuel

3. Droits des Personnes Concernées

Droit (RGPD)	Modalité d'exercice	Délai	Article
Droit à l'information	Notice affichée avant toute utilisation	Immédiat	Art. 13-14
Droit d'accès	Demande écrite au DPO ou portail dédié	1 mois	Art. 15
Droit de rectification	Formulaire de correction des données inexactes	1 mois	Art. 16
Droit à l'effacement	Suppression sur demande, sans obligation légale contraire	1 mois	Art. 17
Droit d'opposition	Arrêt immédiat du traitement sur demande	Immédiat	Art. 21
Droit de portabilité	Export CSV/JSON des données sur demande	1 mois	Art. 20
Non-décision automatisée	Validation humaine obligatoire pour décisions impactantes	Systématique	Art. 22

3.1 Droit de Ne Pas Faire l'Objet d'une Décision Entirement Automatisée (Art. 22 RGPD)

L'article 22 du RGPD s'applique uniquement lorsque la décision automatisée produit un effet juridique ou affecte significativement la personne. Le système distingue donc deux régimes d'application :

Régime 1 | Réponses d'assistance simple (Art. 22 non applicable)

Les réponses à des requêtes générales (résumés, explications, questions pédagogiques) sont transmises directement à l'utilisateur. Elles ne produisent aucun effet juridique ni impact significatif. Un avertissement obligatoire rappelle le caractère automatique de la réponse et invite l'utilisateur à exercer son esprit critique. La responsabilité de l'usage incombe à l'utilisateur final.

Régime 2 | Décisions à impact académique (Art. 22 pleinement applicable)

Toute décision susceptible d'affecter significativement un étudiant (évaluation, orientation, résultat) suit impérativement le circuit de validation ci-dessous, AVANT toute communication à la personne concernée :

Étape	Action	Acteur	Traçabilité
1	Système IA génère une suggestion	Système automatique	Log horodaté enregistré
2	Validation / modification / rejet	Responsable humain habilité OBLIGATOIRE	Identité + date consignées
3	Communication de la décision finale	Responsable humain	Décision finale archivée

4. Analyse d'Impact (AIPD - Art. 35 RGPD)

4.1 Nécessité d'une AIPD

Conformément à l'article 35 RGPD et aux lignes directrices WP248 du G29, une AIPD est obligatoire dès lors qu'au moins deux critères du CEPD sont remplis. Le système IA de l'ENSA satisfait les critères suivants :

Critère CEPD	Présent ?	Justification
Traitement automatisé / évaluation systématique	OUI	Génération automatique de réponses sur requêtes utilisateurs
Traitement à grande échelle	POTENTIEL	Plusieurs centaines d'utilisateurs internes potentiels
Surveillance systématique	NON	Journalisation à des fins d'audit uniquement
Données sensibles (Art. 9 RGPD)	NON	Interdiction technique et procédurale totale
Décision automatisée impactante	MODÉRÉ	Assistance à la décision et supervision humaine obligatoire

Conclusion : AIPD OBLIGATOIRE avant tout déploiement (2 critères CEPD remplis : règle WP248)

4.2 Risques et Mesures de Réduction

Risque	Probabilité	Gravité	Mesure de réduction
Biais algorithmique / discrimination	Moyenne	Élevée	Supervision humaine, révision périodique du système
Hallucinations / erreurs IA	Élevée	Moyenne	Avertissement systématique, validation humaine obligatoire
Fuite de données (data breach)	Faible	Élevée	Chiffrement AES-256, audit sécurité, plan d'incident
Atteinte à la vie privée	Faible	Élevée	Filtrage automatique données sensibles, interdiction saisie
Conservation excessive des données	Moyenne	Moyenne	Politique de rétention documentée, purge automatique
Dépendance excessive à l'IA	Élevée	Moyenne	Formation utilisateurs, avertissements, limites documentées

5. Gouvernance Éthique du Système IA

5.1 Acteurs et Responsabilités

Acteur	Rôle	Obligations RGPD	Responsabilité IA
Responsable de traitement (ENSA)	Définit finalités et moyens du traitement	Art. 5, 24, 25, 30, 35	Accountability globale
Sous-traitant (Hébergeur)	Infrastructure technique et hébergement	Art. 28 - Contrat obligatoire	Sécurité technique des données
DPO - Délégué Protection Données	Conseil, contrôle conformité, liaison CNDP	Art. 37-39 RGPD	Audit conformité IA, gestion AIPD
Utilisateur final (Étudiants/Personnel)	Utilise le système selon la politique d'utilisation	Sujet des droits Art. 13-22	Responsabilité des requêtes saisies

5.2 Supervision Humaine et Transparence

- Validation humaine obligatoire pour toute décision académique impactante avant communication à l'utilisateur (Art. 22 RGPD) ;
- Procédure de contestation ouverte à tout utilisateur, traitée en 5 jours ouvrés ;
- Traçabilité complète : chaque interaction est journalisée avec horodatage et identifiant pseudonymisé ;
- Information préalable : notice explicite indiquant l'usage d'une IA avant toute interaction ;
- Avertissement systématique sur chaque réponse rappelant son caractère automatique et ses limites ;
- Revue trimestrielle par le comité de supervision IA pour détecter les dérives potentielles.

6. Exigences Techniques de Conformité (Art. 32 RGPD)

Composant	Technologie retenue (Open Source)	Justification RGPD/Sécurité
Backend	Python 3.x + Flask	Open source, contrôle total du code, aucun transfert vers tiers
Base de données	SQLite / PostgreSQL	Stockage local, maîtrise totale, aucun transfert hors ENSA
Interface	HTML5/CSS3 - Templates Jinja2	Sans dépendance CDN externe porteur de trackers
Authentification	Sessions Flask + hachage bcrypt	Art. 32 - Sécurité des données d'authentification
Journalisation	Module logging Python + SQLite horodaté	Traçabilité des accès, conformité Art. 5.2 RGPD

Les mesures de sécurité complémentaires incluent : filtrage automatique des données sensibles à l'entrée, chiffrement TLS 1.3 en transit, permissions système restreintes sur la base de données, et protection CSRF par tokens.

7. Définition de Conformité : Definition of Compliance

Le système IA est considéré conforme au cadre juridique et éthique applicable si et seulement si l'ensemble des critères suivants sont satisfaits :

Critère de conformité	Référence réglementaire	Statut
Bases légales du traitement identifiées et documentées	Art. 6 & 30 RGPD	CONFORME
Droits des personnes garantis et exercice facilité	Art. 12 à 22 RGPD	CONFORME
Mesures de sécurité techniques et organisationnelles définies	Art. 25 & 32 RGPD	CONFORME
Responsabilité clairement attribuée à chaque acteur	Art. 24, 28, 37 RGPD	CONFORME
Risques éthiques identifiés et mesures de réduction définies	Art. 35 RGPD + Lignes CEPD	CONFORME
Supervision humaine prévue et validation avant décision impactante	Art. 22 RGPD + Principes IA UE	CONFORME
AIPD réalisée avant déploiement	Art. 35 RGPD	CONFORME
Registre des activités de traitement tenu à jour	Art. 30 RGPD	CONFORME
Utilisateurs informés de l'usage de l'IA avant interaction	Art. 13 + Principe transparence	CONFORME
Données sensibles techniquement exclues du traitement	Art. 9 RGPD	CONFORME

Le système est déclaré CONFORME : tous les critères de la Definition of Compliance sont satisfaits.

8. Conclusion

La présente analyse démontre que le déploiement du système IA à l'ENSA Béni Mellal peut être réalisé dans le respect intégral du RGPD et des principes éthiques de l'IA, sous réserve de la mise en œuvre rigoureuse des mesures identifiées. Les points essentiels sont :

- Base légale solide fondée sur l'Art. 6.1.e (mission d'intérêt public), complétée par le consentement explicite ;
- Six principes fondamentaux de l'Art. 5 RGPD opérationnalisés par des mesures concrètes documentées ;
- Droits des personnes garantis par des mécanismes d'exercice accessibles dans les délais réglementaires ;
- AIPD obligatoire réalisée avant tout déploiement, avec mesures de réduction des risques adéquates ;
- Deux régimes distincts pour l'Art. 22 : réponses simples transmises avec avertissement, décisions impactantes soumises à validation humaine obligatoire AVANT communication ;
- Architecture de gouvernance claire avec quatre acteurs identifiés et responsabilités définies ;
- Critères de la Definition of Compliance intégralement satisfaits.

9. Références Réglementaires

- Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 (RGPD) ;
- Lignes directrices CEPD/EDPB sur l'AIPD - WP248 (G29) ;
- Lignes directrices éthiques pour une IA digne de confiance, Commission Européenne, 2019 ;
- Proposition de Règlement sur l'Intelligence Artificielle (AI Act), Commission Européenne, 2021 ;
- Recommandation CM/Rec(2020)1 du Comité des Ministres du Conseil de l'Europe ;
- Guidelines 05/2020 du CEPD sur le consentement (Art. 6.1.a RGPD).